

Unit-3

1. Define a Firewall. How does it protect a network?

ANS:

A Firewall is a security system (hardware, software, or both) that monitors and controls incoming and outgoing network traffic based on predefined security rules.

It acts as a barrier between a trusted internal network (e.g., your organization's LAN) and an untrusted external network (e.g., the Internet).

How Firewall Protects a Network:

(a) Packet Filtering

- Checks each data packet's IP address, port number, and protocol.
- Blocks malicious or unauthorized packets.
- Example: Block all traffic from 192.168.1.50 or block port 23 (Telnet).

(b) Stateful Inspection

- Tracks the state of active connections.
- Only allows packets that match a valid session (e.g., response to a request).
- Example: If you request a webpage, the firewall allows only related packets back.

(c) Proxy Service

- Acts as a middleman between users and the internet.
- Hides internal IP addresses, providing anonymity and reducing risks.

(d) Network Address Translation (NAT)

- Masks internal IP addresses with the firewall's public IP.
- Prevents attackers from knowing the internal network structure.

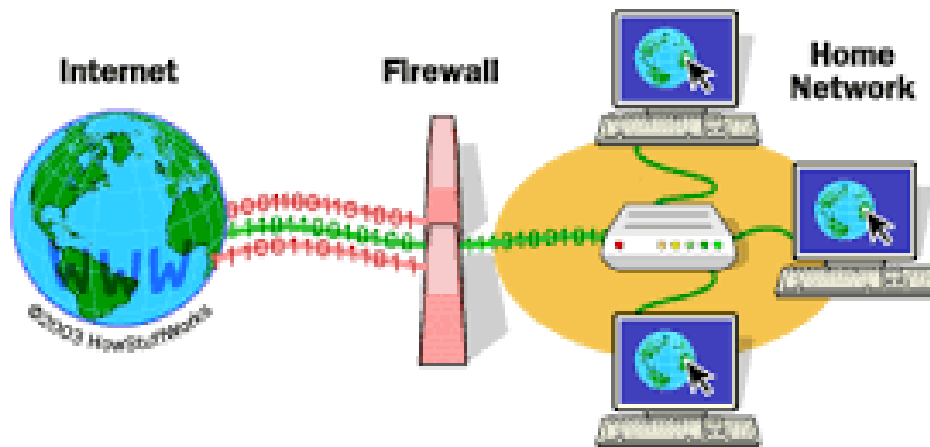
(e) Application-Level Filtering

- Inspects application-level traffic (HTTP, FTP, DNS, etc.).

- Can block access to harmful websites or unauthorized apps.

3. Benefits of Firewall

- Prevents Unauthorized Access – Blocks hackers from entering the network.
- Stops Malware/Worms – Filters suspicious traffic.
- Protects Confidential Data – Ensures sensitive data doesn't leak out.
- Controls Employee Access – Restricts websites/apps (e.g., social media).
- Creates Security Policies – Enforces organization-wide security rules.



Example:

- In a banking system, a firewall can block unauthorized login attempts and prevent malware-infected traffic from reaching servers.

2. Differentiate between Packet Filter and Firewall.

ANS:

Aspect	Packet Filter	Firewall
Definition	A simple security mechanism that filters data packets based on IP addresses, ports, and protocols.	A broader security system (hardware/software) that monitors, filters, and controls all incoming and outgoing network traffic.
Scope	Works only at network layer (Layer 3) and sometimes transport layer (Layer 4) .	Works across multiple layers (network, transport, and application layers).
Decision Criteria	Allows or blocks packets based on IP, port, and protocol rules .	Uses advanced rules : packet filtering, stateful inspection, NAT, application-level filtering, intrusion detection, etc.
State Awareness	Stateless – does not track the state of connections.	Stateful – tracks ongoing sessions and allows only valid responses.
Complexity	Simple and fast but less secure.	More complex, resource-intensive, but highly secure.
Protection Level	Provides basic filtering only ; cannot stop advanced attacks.	Provides comprehensive protection against malware, intrusion, DoS, and unauthorized access.
Example	Cisco Access Control Lists (ACLs) in routers.	pfSense Firewall, Cisco ASA, Palo Alto Next-Gen Firewall.

3. Explain Packet characteristics to filter in Firewall.

ANS:

A firewall filters network traffic by examining different characteristics of packets. These characteristics act as rules to allow or block traffic.

1. Source IP Address

- Identifies the originating device of the packet.
 - Firewall can block traffic from suspicious or blacklisted IPs.
 - Example: Blocking requests from 192.168.1.10 if it's a compromised system.
-

2. Destination IP Address

- Specifies the receiver's address.
 - Helps to restrict access to internal systems.
 - Example: Allow only company's web server IP to receive HTTP requests.
-

3. Protocol

- Defines the communication protocol used.
 - Firewalls can permit or deny based on protocol type.
 - Example: Allow HTTP (TCP port 80) but block Telnet (TCP port 23).
-

4. Source Port Number

- Identifies the port number on sender's side.
 - Used to block suspicious applications or malware.
 - Example: Block traffic originating from random high ports often used by Trojans.
-

5. Destination Port Number

- Identifies the service being requested on the target machine.
 - Example:
 - Allow DNS (port 53), HTTPS (port 443).
 - Block FTP (port 21) to prevent file transfers.
-

6. Packet Direction

- Whether packet is inbound (from outside → inside) or outbound (inside → outside).

- Example: Prevent employees from sending sensitive files outside the network.

7. TCP Flags

- TCP packets contain control flags (SYN, ACK, FIN, RST).
- Firewalls use them to detect unusual connections.
- Example: Block packets with only SYN flag to prevent SYN Flood attacks.

8. Interface

- The entry/exit point of packet in the network.
- Firewall rules can be applied per interface (LAN, WAN, DMZ).
- Example: Block traffic from the internet interface to internal database server.

4. What is the difference between Stateless and Stateful Firewalls?

ANS:

Feature	Stateless Firewall	Stateful Firewall 
Definition	Filters packets individually , without remembering previous packets.	Monitors the state of active connections and makes decisions based on traffic history.
Packet Analysis	Looks only at header information (IP, port, protocol).	Analyzes both header + connection state (SYN, ACK, established sessions).
Context Awareness	No context – treats every packet as new.	Context-aware – knows which packets belong to an existing session.
Security Level	Provides basic security (simple filtering).	Provides stronger security (detects anomalies like SYN floods, session hijacking).
Performance	Faster, as it requires less processing.	Slightly slower, as it maintains a state table .
Resource Usage	Low memory and CPU usage.	Requires more memory and processing power.
Example Use Case	Small networks or when speed is more important than security.	Enterprise networks, banking, e-commerce, where security is critical.
Example Firewall Type	Packet-filtering firewall (early generation).	Next-Gen Firewall, modern IDS/IPS-enabled firewalls.

5. Write short notes on:

(a) NAT (Network Address Translation)

ANS:

Network Address Translation (NAT) is a method used by firewalls or routers to modify the IP address information in packet headers while they are in transit.

- It allows multiple devices in a private network (using private IP addresses) to access the internet using a single public IP address.

Why NAT is Needed?

- IP Address Conservation – IPv4 addresses are limited, NAT helps multiple systems share one public IP.
- Security – Hides internal private IPs from the outside world.
- Flexibility – Enables private IP networks to communicate with public networks without changing addressing schemes.

Types of NAT:

Static NAT:

- One private IP is mapped to one public IP.
- Example: A web server inside the LAN is mapped to a fixed public IP.

Dynamic NAT:

- A private IP is mapped to any available public IP from a pool.
- Example: Employees' PCs are dynamically assigned temporary public IPs when accessing the internet.

PAT (Port Address Translation) / NAT Overload

- Many private IPs share one public IP by using different port numbers.
- Example: Home Wi-Fi where many devices (laptop, phone, TV) access the internet via one ISP public IP.

Example:

- Without NAT: PC (192.168.1.2) cannot directly connect to Google because private IPs are not routable on the internet.
- With NAT: Router translates 192.168.1.2 → 203.0.113.5 so that Google sees only the public IP.

(b) Port Forwarding

ANS:

Port Forwarding is a networking technique that allows external devices on the internet to access services hosted inside a private/local network by forwarding incoming traffic from a specific port of a public IP to a private IP and port.

It is commonly used to make internal services (like web servers, FTP, CCTV, or gaming servers) available to external users.

Why Port Forwarding is Needed?

- Remote Access – Access home/office servers from anywhere.
- Hosting Services – Host a website or FTP server on a private network.
- Gaming/VoIP – Allows online games or applications to connect directly.
- Security Control – Only selected ports/services are made public.

How It Works?

- A router/firewall listens on a specific public port.
- When traffic arrives, it is redirected (forwarded) to the correct private IP and port inside the LAN.

Types of Port Forwarding

Local Port Forwarding:

- Redirects traffic from the local computer to a remote service.

- Example: Accessing a database inside a secure network.

Remote Port Forwarding:

- Allows remote users to connect to a service in your private network.
- Example: Remote employee accessing office intranet.

Dynamic Port Forwarding:

- Routes traffic dynamically through a secure tunnel (like SSH).
- Example: Secure browsing using SSH tunneling.

Example:

- Suppose you want to host a web server on your PC (192.168.1.10:80).
- Your router's public IP is 203.0.113.5.
- By setting up port forwarding rule: 203.0.113.5:8080 → 192.168.1.10:80
- Anyone typing http://203.0.113.5:8080 will reach your internal web server.

6. Explain the basics of Virtual Private Networks (VPNs).

ANS:

A Virtual Private Network (VPN) is a secure communication technology that allows users to create a private, encrypted tunnel over a public network (like the Internet).

It ensures that data traveling between a user and the destination remains confidential, authenticated, and protected.

Basics / Working of VPN:

- A user connects to the VPN client software on their device.
- The client establishes a secure tunnel with the VPN server using encryption protocols (e.g., IPSec, SSL/TLS).
- All the user's network traffic is routed through this tunnel.
- The VPN server forwards the traffic to the final destination (websites, services, etc.).

- Responses from the destination come back through the VPN tunnel securely.

Key Features of VPN:

- Encryption – Protects data from hackers by converting it into unreadable form.
- Authentication – Ensures only authorized users can connect.
- Data Integrity – Prevents modification of data during transmission.
- Remote Access – Employees can securely access company resources from anywhere.
- Anonymity – Hides user's real IP address and location.

Types of VPN

1) Remote Access VPN

- Used by individuals to connect securely to a private network.
- Example: Employee connecting to office intranet from home.

2) Site-to-Site VPN

- Connects two or more networks (e.g., branch offices) securely over the Internet.
- Example: Head office and branch office communication.

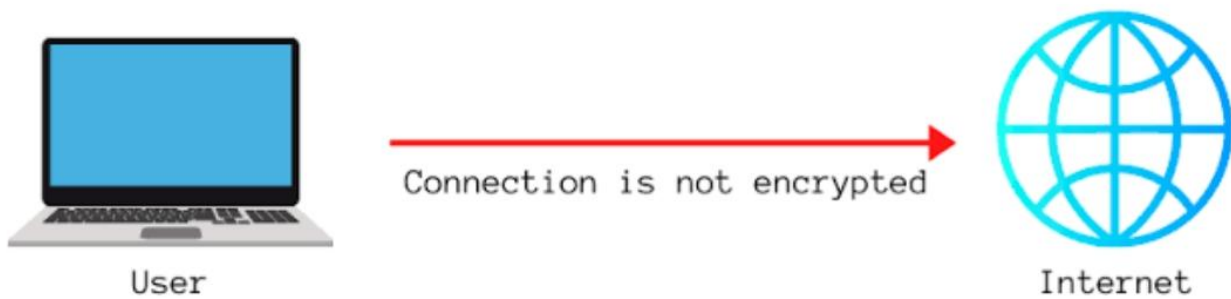
Applications of VPN

- Corporate Use: Remote employees securely access company servers.
- Privacy Protection: Hide browsing activity from ISPs or attackers.
- Bypass Restrictions: Access region-blocked content or websites.
- Secure Transactions: Safe online banking and e-commerce.

Example:

- A bank employee working from home uses a VPN client.
- The VPN encrypts traffic and connects to the bank's VPN server.
- Employee can securely access customer records as if sitting in office.

Without VPN



With VPN



7. Differentiate between Linux Firewall and Windows Firewall.

ANS:

Feature	Linux Firewall	Windows Firewall
Default Tool	Uses iptables (older) or nftables (modern).	Comes built-in with Windows Defender Firewall .
Operating System	Works on Linux/Unix-based systems .	Works on Windows OS only .
Control Type	Command-line based (though GUIs exist, e.g., Firewalld , UFW).	Mostly GUI-based with simple configuration options.
Configuration	More flexible and customizable ; requires technical knowledge.	Easier to configure, user-friendly interface .
Rules Management	Can filter packets by IP, port, protocol, chain (INPUT , OUTPUT , FORWARD).	Rules are created per app or service (Allow/Block specific programs/ports).

Advanced Features	Supports complex rules, NAT, port forwarding, bridging, traffic shaping.	Supports basic inbound/outbound filtering and some advanced rules via Group Policy.
Performance	Lightweight and efficient (suitable for servers).	Uses more system resources compared to Linux firewall.
Use Cases	Widely used on servers, routers, and enterprise systems.	Mainly used on personal PCs and corporate desktops.
Default Policy	Typically deny all, allow specific traffic (needs manual setup).	By default, allows outbound and blocks unsolicited inbound traffic.

8. What is Snort? Explain its working as an Intrusion Detection System.

ANS:

Snort is an open-source network intrusion detection and prevention system (NIDS/NIPS) developed by Martin Roesch.

It can monitor network traffic in real time, perform packet logging, and analyze data to detect suspicious or malicious activities.

Snort is widely used because it is free, lightweight, and highly customizable.

Modes of Operation

Snort can work in different modes:

- Sniffer Mode – Reads packets from the network and displays them on the screen.
- Packet Logger Mode – Logs network traffic to files for later analysis.
- Network Intrusion Detection System (NIDS) Mode – Monitors network traffic in real time and compares it with rules to detect threats.
- Inline Mode (NIPS) – Can also block/stop malicious traffic in real time.

Working of Snort as an IDS

Snort works in a step-by-step pipeline:

1) Packet Capture (Sniffer Engine)

- Captures packets from the network using libpcap library.
- Works like Wireshark but focuses on intrusion detection.

2) Preprocessing

- Organizes packets into meaningful chunks.
- Removes unnecessary data, normalizes packets, and prepares them for detection.

3) Detection Engine

- The heart of Snort.
- Compares traffic against a set of rules and signatures (like antivirus patterns).
- Rules define what constitutes an attack (e.g., port scans, DoS attacks, malware).

4) Alert/Logging

- If traffic matches a rule, Snort generates an alert.
- Alerts can be stored in logs, databases, or displayed on the screen.

5) Output Modules

- Sends results to syslog, database, or monitoring tools.
- Can be integrated with GUIs like Snorby, BASE, or Security Onion.

Applications of Snort:

- Detecting DoS/DDoS attacks.
- Identifying port scans and reconnaissance.
- Monitoring malware traffic and exploits.
- Protecting enterprise networks by alerting administrators of suspicious activity.
- Used in cyber forensics to analyze packet captures.

9. List web application scanning tools and explain any three in detail.

ANS:

A Web Application Scanning Tool is a security software that automatically examines websites, web apps, and web servers to identify vulnerabilities and misconfigurations before attackers can exploit them.

Features of Web Application Scanning Tools:

- Automated Scanning – Finds vulnerabilities without much manual effort.
- Crawling/Spidering – Maps the structure of the web application.
- Vulnerability Detection – Identifies common attacks like SQL Injection, XSS, etc.
- Report Generation – Provides detailed results for developers/security teams.
- Integration – Can be used in DevSecOps pipelines to secure apps during development.

Common Web Application Scanning Tools:

- 1) OWASP ZAP (Zed Attack Proxy)
- 2) Burp Suite
- 3) Nikto
- 4) Acunetix
- 5) Wapiti
- 6) Netsparker
- 7) Arachni
- 8) WebInspect

1. OWASP ZAP (Zed Attack Proxy)

- Type: Open-source, free tool maintained by OWASP.
- Purpose: Finds vulnerabilities in web applications by intercepting and analyzing traffic between the client (browser) and server.

Features:

- Acts as a man-in-the-middle proxy.
- Supports automated and manual scanning.
- Detects vulnerabilities like SQL Injection, XSS, insecure headers, session issues.
- Easy integration with other DevSecOps tools.

Use Case Example:

- A developer tests a login page with OWASP ZAP → it finds weak session cookies and potential SQL injection flaws.

2. Burp Suite

- Type: Commercial (Community version free, Pro is paid).
- Purpose: One of the most popular tools for penetration testing of web apps.

Features:

- Acts as a proxy server to intercept HTTP/HTTPS traffic.
- Includes tools like Spider (crawls application), Intruder (automated attack tool), Repeater (manual testing), Scanner (Pro version).
- Detects flaws such as SQL Injection, XSS, authentication bypass, CSRF.

Use Case Example:

- A security tester uses Burp Intruder to try multiple payloads against a search form → discovers Reflected XSS vulnerability.

3. Nikto

- Type: Open-source command-line web server scanner.
- Purpose: Scans web servers for dangerous files, outdated software, and misconfigurations.

Features:

- Identifies outdated web servers (Apache, Nginx, IIS).
- Checks for default files, insecure scripts, and known vulnerabilities.
- Can detect over 6,700 potentially dangerous files and programs.
- Lightweight and widely used in penetration testing.

Use Case Example:

- Running Nikto on a target website shows that the server is running an outdated Apache version vulnerable to CVE exploits.

10. Write short notes on:

(a) Nikto

ANSWER in above question

(b) W3af

ANS:

W3af stands for Web Application Attack and Audit Framework.

W3af is a web application penetration testing tool that helps security testers by:

- Scanning for vulnerabilities (audit mode).
- Exploiting vulnerabilities (attack mode).
- Providing reports to improve the security of web applications.

W3af Architecture:

- 1) Core – Manages configurations, plugins, and execution.
- 2) Plugins – Divided into categories:
 - Discovery → Crawling, spidering, identifying entry points.
 - Audit → Testing inputs for vulnerabilities (SQLi, XSS, etc.).
 - Attack → Exploiting discovered vulnerabilities.
 - Output → Reporting results in formats (text, HTML, XML).
 - Mangle → Modifies requests to bypass filters.

W3af Workflow:

- 1) Target Definition
 - User specifies the target web application (e.g., `http://example.com`).
- 2) Discovery Phase
 - W3af crawls the application to identify forms, links, and input points.

3) Audit Phase

- Sends crafted payloads to test for vulnerabilities (SQLi, XSS, etc.).

4) Attack Phase

- Optionally exploits vulnerabilities (if enabled).

5) Report Generation

- Generates reports with detailed vulnerabilities and recommendations.

Example Use Cases:

- SQL Injection Testing → Finds vulnerable login forms.
- XSS Detection → Identifies places where malicious JavaScript can be injected.
- Authentication Testing → Detects weak or broken authentication.
- Penetration Testing → Automates initial reconnaissance and auditing.

(c) cURL

ANS:

- cURL stands for Client URL.
- cURL is a network utility that allows users to send and receive data using URLs across a wide range of supported protocols.

Supported Protocols:

cURL supports over 20+ protocols, including:

- HTTP / HTTPS
- FTP / FTPS
- SCP, SFTP
- LDAP
- SMTP, POP3, IMAP
- FILE (local files)
- TFTP

Features:

- Cross-Platform – Works on all major OS.
- Multiple Protocols – Wide range of protocol support.
- Authentication Support – Basic, Digest, NTLM, Negotiate.
- Proxy Support – Can route through HTTP/SOCKS proxies.
- File Upload & Download – Easily upload or download files.
- SSL/TLS Support – Secure communication.
- Automation – Can be used in scripts for automated tasks.

Syntax:

curl [options] [URL]

Important Options:

- O → Save output to file with same name.
- o filename → Save output to specified filename.
- I → Fetch only headers (HEAD request).
- X → Specify request method (GET, POST, PUT, DELETE).
- d → Send data with POST request.
- u → Specify username and password for authentication.

Advantages:

- Lightweight and fast.
- Works across platforms.
- Highly scriptable (useful in automation).
- Supports a wide variety of protocols.

Limitations:

- Command-line only (not GUI).
- Limited reporting features compared to specialized scanners.
- Requires knowledge of commands and options.

11.What is the role of OpenSSL and Stunnel in Cyber Security?

ANS:

1. OpenSSL

- OpenSSL is an open-source cryptographic toolkit.
- Provides implementation of SSL (Secure Sockets Layer) and TLS (Transport Layer Security) protocols.
- Essential for secure communications on the internet.

Functions of OpenSSL:

1) Encryption & Decryption:

- Protects data from being read by unauthorized users.
- Example: Encrypting files or network traffic.

2) Certificate Management:

- Generates public/private key pairs.
- Issues and verifies X.509 digital certificates.

3) Secure Protocol Implementation:

- Implements SSL/TLS protocols for HTTPS, FTPS, SMTPS, etc.

4) Hashing:

- Supports hashing algorithms like SHA, MD5, SHA-256 for data integrity.

5) Command-Line Utility:

- Provides the openssl command to generate keys, test servers, encrypt/decrypt files.

1.3 Common Use Cases

- **Creating a private key**

```
bash
```

[Copy code](#)

```
openssl genrsa -out private.key 2048
```

Role in Cyber Security:

- Provides confidentiality (encryption).
- Provides integrity (hashing & signatures).
- Provides authentication (certificates).
- Used in HTTPS, VPNs, email security, and secure file transfers.

2. Stunnel

ANS:

Stunnel is an SSL/TLS tunneling proxy.

It allows applications that do not natively support encryption to securely transmit data using SSL/TLS.

Works by wrapping plaintext communication inside an encrypted tunnel.

Functions of Stunnel

1) Encrypts Legacy Applications:

- Example: An old POP3/IMAP email server without SSL → secured using Stunnel.

2) SSL/TLS Gateway:

- Converts insecure protocols (HTTP, FTP, Telnet) into secure ones (HTTPS, FTPS, SSH-like).

3) Client & Server Mode:

- Can run on server side to provide SSL-enabled services.
- Can run on client side to connect securely to remote SSL servers.

Common Use Cases:

Secure POP3 Email Communication:

- Client connects to Stunnel → Stunnel encrypts traffic → Forwards to POP3 server.

Secure Remote Database Access:

- Wraps MySQL/PostgreSQL traffic in SSL to protect against eavesdropping.

VPN-like Tunneling:

- Provides encrypted tunnels for applications not supporting VPNs.

Role in Cyber Security:

- Protects legacy systems without built-in encryption.
- Provides confidentiality and integrity for data-in-transit.
- Helps in compliance with security standards (like PCI-DSS for financial data).

12.Explain Sqlmap and its importance in SQL injection testing.

ANS:

SQLmap is an open-source penetration testing tool.

SQL Injection is a cyber attack where malicious SQL queries are inserted into input fields of a web application.

The attacker manipulates the database to:

- Steal sensitive data (usernames, passwords, credit card info).
- Modify or delete data.

- Bypass authentication.
- Even gain full server control in severe cases.

Features of SQLmap:

1 Automatic Detection

- Identifies various types of SQL injections:
 - Boolean-based blind
 - Time-based blind
 - Union-based
 - Error-based
 - Out-of-band

2 Database Fingerprinting

- Detects the underlying database type and version (MySQL, Oracle, MSSQL, PostgreSQL, etc.).

3 Database Dumping

- Extracts data such as usernames, passwords, credit card details, tables, and schemas.

4 Privilege Escalation

- Identifies database user privileges and tries to gain admin access.

5 File System Access

- Reads/writes files on the database server (if privileges allow).

Syntax

bash

 Copy code

```
sqlmap -u "http://example.com/page.php?id=1"
```

- `-u` specifies the target URL.
- SQLmap tests the parameter (`id=1`) for SQL injection.

Example Commands

1. List Databases

bash

 Copy code

```
sqlmap -u "http://example.com/page.php?id=1" --dbs
```

Importance of SQLmap in Cyber Security:

1) Automation of SQL Injection Testing:

- Saves time by automating detection & exploitation, which is tedious manually.

2) Wide Database Support:

- Works across different database engines (MySQL, Oracle, PostgreSQL, MS SQL, etc.).

3) Security Auditing:

- Helps penetration testers identify database vulnerabilities before attackers do.

4) Prevention and Awareness:

- By simulating attacks, developers can patch vulnerabilities (e.g., by using parameterized queries).

5) Regulatory Compliance:

- Supports organizations in meeting compliance standards like PCI-DSS, HIPAA, and ISO 27001 that require regular vulnerability testing.

13. What are DVWA and Webgoat? How are they used in web app testing?

ANS:

1) DVWA (Damn Vulnerable Web Application)

DVWA is a PHP/MySQL-based web application that is intentionally insecure. It allows security professionals, students, and developers to practice finding and exploiting common web vulnerabilities.

Key Features:

Multiple Security Levels

- Low → Medium → High → Impossible
- Helps learners understand how increasing security makes attacks harder.

Pre-installed Vulnerabilities:

- SQL Injection
- Command Injection
- Cross-Site Scripting (XSS)
- File Inclusion
- CSRF (Cross-Site Request Forgery)

Realistic Testing Environment:

- Mimics real-world insecure coding practices.

Use in Web App Testing

Learners can:

- Test tools like SQLmap, Burp Suite, OWASP ZAP.
- Understand how attacks work and how to patch them.
- Practice safe exploitation without legal risks.

2) WebGoat:

ANS:

WebGoat is an open-source project maintained by OWASP.

It is a Java-based insecure web application designed for teaching web application security concepts.

Key Features:

Interactive Learning Platform

Contains lessons, challenges, and hands-on labs.

Example: “Try SQL Injection” → user exploits → then reads about secure coding fixes.

Wide Range of Vulnerabilities:

- SQL Injection
- Broken Authentication
- Insecure Direct Object References (IDOR)
- Cross-Site Scripting (XSS)
- Session Management Issues
- XML External Entity (XXE) attacks

Educational Focus

Each vulnerability is explained with:

- Theory
- Practical exploitation
- Secure coding guidelines

Use in Web App Testing

Used by:

- Students → to learn OWASP Top 10 vulnerabilities.
- Penetration Testers → to practice exploits.
- Developers → to understand secure coding practices.

14. Write notes on Password Cracking Tools: John the Ripper, L0phtCrack, Pwdump, Hydra.

ANS:

Password cracking is the process of recovering passwords from stored or transmitted data. Attackers, penetration testers, and security analysts use password cracking tools to test password strength, identify weak authentication mechanisms, and perform security audits.

1) John the Ripper (JtR)

- A popular open-source password cracking tool.
- Works on Unix, Windows, and macOS.
- Mainly used to crack hashed passwords.

Features:

- Supports multiple hash formats: DES, MD5, SHA, LM hashes.
- Provides dictionary attacks, brute force attacks, and hybrid attacks.
- Allows custom wordlists and rules for smart cracking.

Use Case:

- Example: Crack Linux /etc/shadow password hashes.
- Used in penetration testing to check for weak user passwords.

2. L0phtCrack

- A Windows password auditing and recovery tool.
- Originally created by L0pht Heavy Industries (later acquired by Symantec, now independent again).
- Specializes in cracking Windows NT/2000/XP/2003 password hashes.

Features:

- Extracts password hashes from the Windows SAM (Security Accounts Manager).
- Uses dictionary, brute force, and hybrid attacks.
- Provides audit reports on password strength.
- Supports remote password recovery across networks.

Use Case:

- Example: An IT administrator audits weak Windows passwords in an enterprise.
- Helps organizations enforce strong password policies.

3. Pwdump

- A Windows password hash dumping tool.
- Extracts LM and NTLM password hashes from the Windows SAM database.
- Often used in combination with other cracking tools like John the Ripper or L0phtCrack.

Features:

- Reads hashes from Windows LSASS (Local Security Authority Subsystem Service) process.
- Multiple versions (Pwdump1, Pwdump2, ... Pwdump7).
- Can bypass Windows restrictions to dump password hashes.

Use Case:

- Example: A penetration tester dumps NTLM hashes with Pwdump → cracks them with John the Ripper.
- Enables attackers to escalate privileges if weak passwords are used.

4. Hydra (THC-Hydra)

- A fast and flexible network login cracker developed by The Hacker's Choice (THC).
- Works against multiple network protocols.

Features:

- Supports over 50 protocols: HTTP, HTTPS, FTP, SSH, Telnet, RDP, MySQL, SMTP, etc.
- Performs dictionary attacks and brute force attacks on login services.
- Multi-threaded → very fast cracking.
- Available on Linux, Windows (via Cygwin), and macOS.

Use Case:

Example: Test SSH login on 192.168.1.10 with a wordlist.